

Final Project & Report

Hi-Zor RAT

Prepared by Xiomar Robertson

UID: 80754382

Table of Contents

Abstract.....	2
Scenario.....	2
Threat Actor.....	3
Exploit Target.....	3
Campaign.....	3
The Exploit.....	3
Kill Chain.....	4
Reconnaissance.....	4
Weaponizing.....	4
Delivery.....	5
Exploit.....	5

StixViz.....	5
Soltra/Edge.....	7
Installation.....	7
Command & Control.....	9
Action on Objectives.....	9
Identification.....	9
Eradication and Recovery.....	10
Lesson Learned.....	10
Exploit References.....	11
References.....	11



Abstract

This report will explain the phases, threats and capabilities of the “Hi-Zor RAT”. This malware threat, in MITRE with ID S0087 ([Hi-Zor, Software S0087 | MITRE ATT&CK®](#)), is a remote access trojan that encrypts C2 with double XOR, uses file obfuscation, uninstalls files, uses string stacking while using applications to act as bait to hide it. This RAT can be a very dangerous tool for remote attackers who can enter a system simply from phishing email, while being able to hide itself to some degree. Plenty of damage can be done to an unsuspecting employee and realized before it’s too late. This malware was first observed on January 27, 2016 ([Sakula Malware Analysis: INOCNATION Campaign Obfuscation | Report | Fidelis Security](#)), and last updated on April 11, 2024 ([Hi-Zor, Software S0087 | MITRE ATT&CK®](#)).

This will be demonstrated using the “Kill Chain” below:



Scenario

Here, we will look at a scenario and determine what characters and actors are determined in a Hi-Zor RAT attack. We will use STIX attributes to organize the scenario.

Threat Actor

For this scenario, the threat actor will be a Philadelphia System Admin named A.J Brown for “Eagle Security” who is trying to launch a historical, widespread attack and leave a legacy on the digital world because he feels like he hasn’t contributed anything to society. A.J wants to expose his exploit target slowly.

Exploit Target

The target will be the system of a rival company’s (Commander Security) top executive, Dr. Jayden Daniels, so he can infiltrate his system, steal his passwords and expose company secrets. He will also aim to execute similar attacks against many other associated executives. Dr. Daniels is known to steal trade secrets from companies like A.J’s.

Campaign

In this scenario, A.J goes home from a long day of unrewarding work. He looks for RATs he can use to deliver through emails, and ultimately, to Jayden Daniel’s email. He’ll go to company seminars, a job interview and a website, all provided by the target company. By finding their emails, A.J can spear-phish recruiters and executives. A.J will send an email disguised as his own company’s trade secrets and send with a Hi-Zor trojan embedded in the HTML file via a fake PDF.

The Exploit

A.J searched the MITRE ATT&CK database for malware used with software, as well as those that are effective while paired with emails. He came across the Hi-Zor trojan and decided to use it. As a plus, he realized that it can also delete files from one’s system and there is not much information about it online for the victims to understand.

Kill Chain

Reconnaissance

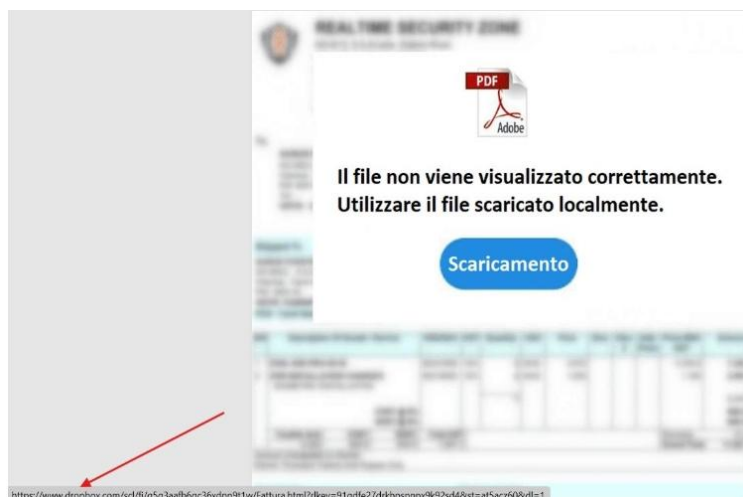
A.J searched for job roles for Dr. Daniels' company, Commander Security, via LinkedIn. There, he found a job posting for which he was able to get the interview for. A.J kept a list of email addresses he planned to phish against and slowly added each one. While searching for Commander Security's website, he comes across PII of the current employees from LinkedIn. There, he logged more addresses to his list. A.J also found out that there was a scheduled public seminar where the top executives were supposed to speak. During the seminar, A.J was able to show off his technological knowledge to the executives much to their surprise. He also was able to network with these executives, and one even offered his personal email. The executive said that seminars are primarily recruiting events for people who are interested and need to get their foot in the door. A.J knew this meant that there were employees without any security experience and little security awareness training. There, A.J knew he had a clear gap to go through.

Weaponizing

A.J searches MITRE to find out just how the Hi-Zor RAT can function. He finds out that Hi-Zor can install files from the Command & Control server using the Ingress Tool Transfer. He sees on the site that "Tools or files may be copied from an external adversary-controlled system to the victim network through the command-and-control channel or through alternate protocols such as ftp"([Ingress Tool Transfer, Technique T1105 - Enterprise | MITRE ATT&CK®](#)). When A.J is inside the system, he can use the Lateral Tool Transfer, which can also use Google Drive with synced folders to copy files ([Lateral Tool Transfer, Technique T1570 - Enterprise | MITRE ATT&CK®](#)). A.J decides to use Google Drive and Cisco's AnyConnect to have a HTML file that tells the user to click to download a supposed PDF. The Hi-Zor RAT installer is the actual file downloaded.

Delivery

As A.J conversates with the executive over email, he says that he knows the company secrets of the company “Eagle Security” which he works for. The executive knows that Dr. Daniels’ company thrives from stolen ideas from competitors and he’s looking to get higher in his good graces. He asks A.J for them and A.J said that he must be hired to the company first. A.J utilizes social engineering to leverage the said executive to get both things that he wants, as well as tell the executive to send them to the employees too. As they agree, A.J tells the executive to get the Cisco AnyConnect VPN Client so he can send privately without anyone knowing, use Cisco’s AnyConnect and use Google Drive with them. A.J sends the Google Drive file, and the executive downloads said file (PDF example from [Multilayered Email Attack: How a PDF Invoice and Geo-Fencing Led to RAT Malware | FortiGuard Labs](#) below).

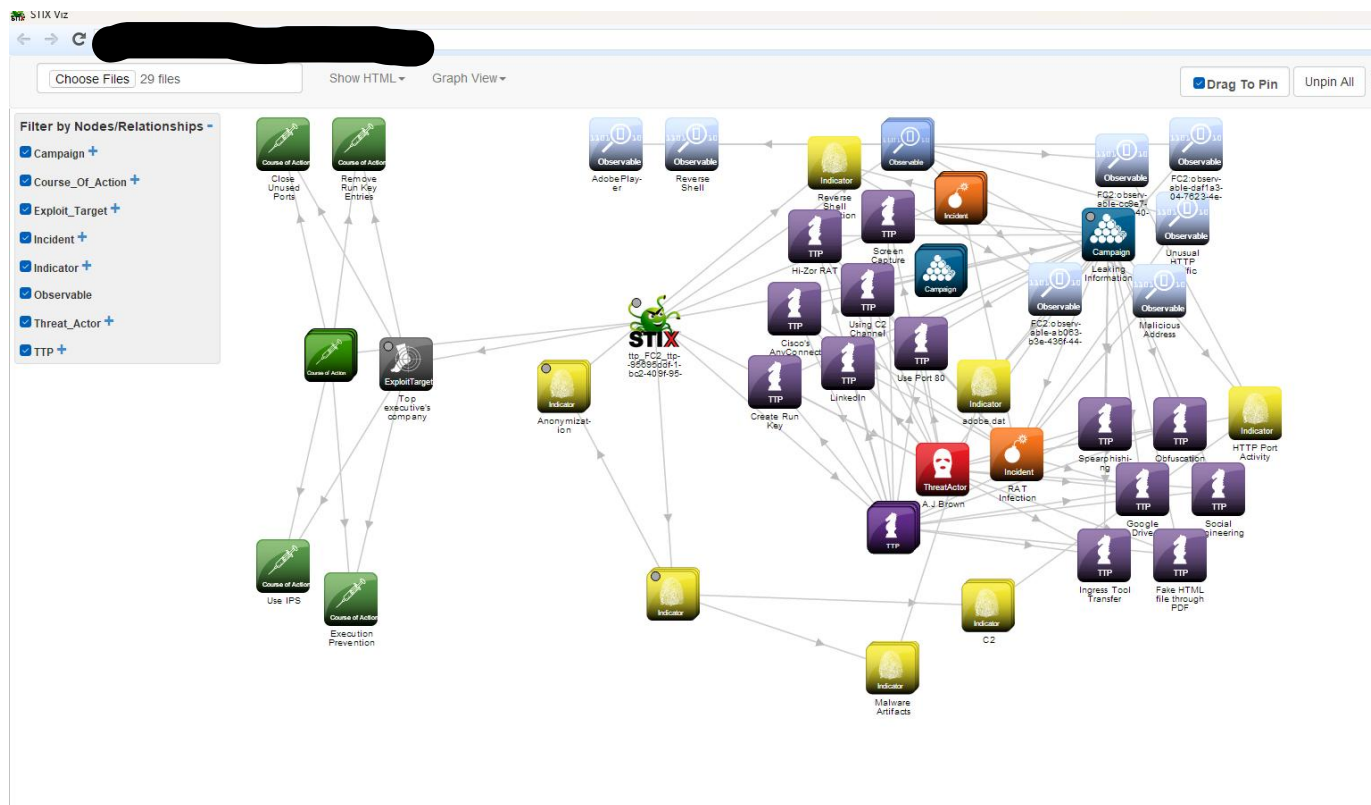


Exploit

The executive’s PC will download the PDF and when the Hi-Zor Trojan is downloaded and executed, a file named regsvr32.exe will be executed as a reverse shell is created. A.J will be able to use this reverse shell to install the malware and also transfer/delete existing company trade secrets, while the executive keeps his computer on. Hi-Zor is able to obfuscate files, which, in this context, will make regsvr32.exe hard to find and analyze via encryption.

Stixviz Representation

Here is the Stixviz representation:



Soltra/Edge Representation


Campaign
PC2:campaign-a3c6704a-99c5-48d2-a837-1dd9df66df90

Revisions: 2025-12-01 23:38:25 ~ admin ▼

Summary

Title	Leaking Information

About

Added by	admin
On	2025-12-01T18:38:25
eTLP	AM/BER
Namespace	http://usf.edu

Description

Adversary wants to steal and expose info
(no long description)

Details

Matching Content

Referenced By

Type	Title	Id
Threat Actor	A.J Brown	PC2:threatactor-dbd83be1-315d-48ec-98ba-771ef3c1c6e1

Type	Title	Id
Indicator	Reverse Shell Execution	PC2:indicator-fa39057c-9719-4bu0-8837-3e773eadab05
Observable	(untitled)	PC2:observable-ah061b3e-436f-444f-a71c-3e766b6a7141
TTP	Obfuscation	PC2:ttp-86fc9f51-7353-4d2e-9919-546b0b0b5da
Incident	RAT Infection	PC2:incident-9565455-cbf0-418d-b7d0-e57908c881c8
TTP	Using C2 Channel	PC2:ttp-dcaff4ca-2797-41ec-a7cb-e04e01857152
Observable	Unusual HTTP Traffic	PC2:observable-cb40a11d-d61e-4aeF-843a-6fb17c0e5b1c
TTP	Google Drive	PC2:ttp-593d10a8-b63b-423d-b334-b62838c843da
TTP	Hi-Zor RAT	PC2:ttp-78ec003d-3fa8-4e5b-bbc5-50bc9FFdF969
TTP	Disco's AnyConnect	PC2:ttp-e6313dc0-4653-4e93-b7cf-da25f3e58dfa
TTP	LinkedIn	PC2:ttp-818bfdd5-c78c-4d48-a35b-972eb63ad084
Indicator	HTTP Port Actvty	PC2:indicator-4c3d2aab-5cca-475d-92a7-2e4ba63b408d
Observable	Malicious Address	PC2:observable-b23dbf27-9c3c-4450-9cca-424e22a2273b
TTP	Using C2 Channel	PC2:ttp-dcaff4ca-2797-41ec-a7cb-e04e01857152
TTP	Fake HTML file through PDF	PC2:ttp-95695ddf-1bc2-409f-95ea-13164b208870
TTP	Google Drive	PC2:ttp-593d10a8-b63b-423d-b334-b62838c843da
TTP	Spearphishing	PC2:ttp-d82ef75c-ef17-4000-8a5a-083b0e232c98
TTP	Hi-Zor RAT	PC2:ttp-78ec003d-3fa8-4e5b-bbc5-50bc9FFdF969
TTP	Disco's AnyConnect	PC2:ttp-e6313dc0-4653-4e93-b7cf-da25f3e58dfa
TTP	LinkedIn	PC2:ttp-818bfdd5-c78c-4d48-a35b-972eb63ad084
TTP	Social Engineering	PC2:ttp-776d5ad3-d801-4c1c-a54b-125f3681a429
Indicator	HTTP Port Actvty	PC2:indicator-4c3d2aab-5cca-475d-92a7-2e4ba63b408d
Observable	(untitled)	PC2:observable-c9e70ff1-0eb8-40e7-937c-01134a26208c
Indicator	adobe.dat	PC2:indicator-dbac30b3-e5a0-485b-ad88-46e5ca0db465
Observable	(untitled)	PC2:observable-da3a304-7623-4e13-ae3b-4ea700f284e6
TTP	Create Run Key	PC2:ttp-81f6e5af-a00c-4a35-927c-5ccc1a0ed0eb
TTP	Screen Capture	PC2:ttp-ad479384-6dd0-49c3-b8d8-e4d92e037817
TTP	Ingress Tool Transfer	PC2:ttp-8f812d69-7e71-43f2-8d2a-b8f4aa440928
TTP	Use Port 80	PC2:ttp-cd2686de-7f2f-43f7-9e96-fba58ccbb81c

Installation

As the file is downloading, A.J is able to configure the trojan to make sure it is persistent by making the program start after the user logs in ([Boot or Logon AutoStart Execution: Registry Run Keys / Startup Folder](#)).

This is achieved by creating a certain registry run key, where the regsvr32.exe file is booted.

While the Hi-Zor sample entrenches in the system here:

```
Key:          HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
Value name:   AdobePlayer
Value data:   regsvr32 /s "%APPDATA%\adobe\adobe.dat"
```

The “adobe.dat” at the end of the value data is how the Hi-Zor RAT can copy itself before being ingrained in the system with the registry run key. The same technique is used in the malware named Derusbi ([Win32/Derusbi threat description – Microsoft Security Intelligence](#)).

Win32/Derusbi encrypts its components to avoid antimalware scanners. It decrypts the files in memory when it needs to use them.

Registry modifications

Variants can modify the following registry entries so that they run each time you start your PC:

In subkey: *HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows*
Sets value: *LoadApplnit_DLLs*
With data: “1”

In subkey: *HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows*
Sets value: *Applnit_DLLs*
With data: “<malware path>”, for example [%APPDATA%](#)Intel\jloadL.dat

Next, a reverse shell like this is created ([Reverse Shell Cheat Sheet With Examples \[100% Working\] | GoLinuxCloud](#)).

```
golinux@kali:~$
golinux@kali:~$ nc -lvp 4444
listening on [any] 4444 ...
172.16.6.140: inverse host lookup failed: Unknown host
connect to [172.16.6.141] from (UNKNOWN) [172.16.6.140] 5889
4
johndoe@debian:~$
johndoe@debian:~$ ls
ls
Desktop
Documents
```

Within the shell, A.J will use Ingress Tool Transfer with commands like “...copy, finger, certutil, and PowerShell commands such as IEX(New-Object Net.WebClient).downloadString() and Invoke-WebRequest”).

Upon installation, this will boot and A.J is ready to continue.

Command and Control

When A.J takes control of the infected system, he will use the reverse shell to execute the Ingress Tool Transfer to transfer malicious “dummy” files onto the computer. The victim will think that it is the actual company secrets. A.J will also use Ingress to delete existing company secrets after logging them with snapshots. A.J is able perform command-and-control via HTTP (port 80) while it is obfuscated using double XOR, which is called string stacking. The obfuscation encodes the files in the C2 channel to make it more difficult to detect.

Actions on Objectives

While A.J is in a current conversation with the executive, he waits until nighttime so it can be the last thing done in the day. When the executive installs both Cisco AnyConnect VPN and Client, A.J gets the payload ready to send. After it was sent, they said their goodbyes while A.J remained awake. When the files download, the reverse shell executes and A.J can transfer his “dummy” file into the infected system. A.J finds company secrets easily and deletes them after recording the information. A.J saves the screen capture to his database with plans to leak them to his own company and the internet.

Incident Handling

Identification

To identify the Hi-Zor Trojan, you must understand what your system looks like when it’s not functioning normally. If your cursor loads continuously and a black box pops up, the reverse shell has been executed. You can also use the Registry Editor to see the registry key. By doing this, you can see the regsvr32.exe in the run key “HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run” and the new startup folder. The Ingress Tool can be identified by abnormal files being transferred to abnormal file drop paths. This can include the tools downloaded ([Detect Registry and Startup Folder Persistence \(Windows\)](#), [Detection Strategy DET0365 | MITRE ATT&CK®](#)).

Eradication and Recovery

To get rid of the Hi-Zor RAT and prevent future issues, you need to understand how to stop Remote Access Tools ([Remote Access Tools, Technique T1219 – Enterprise | MITRE ATT&CK®](#)).

- Disable or Delete Program. Removing the file that was downloaded is the crucial step in making sure the RAT is not present on the system
- Check (close) the ports and firewalls. For the Hi-Zor to work, it has to utilize open ports and leverage it against the system. Monitoring your firewall for abnormal traffic is needed in order see which ports are being exploited. Below is where Hi-Zor is beacons over TLS (<https://www.fidelissecurity.com/threatgeek/archive/introducing-hi-zor-rat/>).

```
POST /-1004122437VICTIM.1a53b0cp32e46g0qio9 HTTP/1.1
```

```
User-Agent: Mozilla/5.0 (Windows NT 6.3; WOW64; Trident/7.0; rv:11.0) like Gecko
```

```
Host: inocnation[dot]com
```

```
Content-Length: 8
```

```
Connection: Keep-Alive
```

- Execution Prevention. Be able to prevent foreign files from being executed immediately. Every file needs to be treated as a potential danger, especially when one is an important executive. “Executable Blocking: Use Case: Prevent execution of binaries from suspicious locations, such as %TEMP% or %APPDATA% directories. Implementation: Block execution of .exe, .bat, or .ps1 files from user-writable directories.” ([Execution Prevention, Mitigation M1038 – Enterprise | MITRE ATT&CK®](#)).
- A way to defend against the Ingress Tool Transfer is to use IPS. This is to detect the signature of the tool.
- Defending against obfuscated tools can include downloading and updating antivirus. Audits are also useful to see anomalies after that fact that it has happened.

Lesson Learned

Stopping the Hi-Zor can easily be accomplished at the beginning with one step. Caution. This is an attack that can be done with great social

engineering skills, and it takes a level head and common sense to realize when you're being exploited. The Hi-Zor is delivered in a file the executive should've thought twice about, why this man named A.J wanted to send company secrets and what he wanted in return. Many times in the Cybersecurity world, it is said that humans are the weakest link in security. You would think a top executive of a security company knows that! But with security awareness training and system hardening, this can be avoided before even sending over an email.

Exploit References

1. Hi-Zor Trojan
2. Sakula
3. MITRE S0087
4. Derusbi
5. Ratty RAT

References

1. MITRE ATT&CK. "Registry Run Keys". [Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder, Sub-technique T1547.001 - Enterprise | MITRE ATT&CK®](#)
2. Cisco AnyConnect. [Cisco AnyConnect Secure Mobility Client v4.x - Cisco](#)
3. MITRE ATT&CK. "Hi-Zor". [Hi-Zor, Software S0087 | MITRE ATT&CK®](#)
4. MITRE ATT&CK. "Ingress Tool Transfer". [Ingress Tool Transfer, Technique T1105 - Enterprise | MITRE ATT&CK®](#)
5. MITRE ATT&CK. "Lateral Tool Transfer". [Lateral Tool Transfer, Technique T1570 - Enterprise | MITRE ATT&CK®](#)
6. Fortiguard Labs. "Multilayered Email Attack". [Multilayered Email Attack: How a PDF Invoice and Geo-Fencing Led to RAT Malware | FortiGuard Labs](#)
7. Fidelis Security. "Sakula Malware Analysis". [Sakula Malware Analysis: INOCNATION Campaign Obfuscation | Report | Fidelis Security](#)
8. CrowdStrike. "Sakula Malware". [Sakula Malware: What Is the INOCNATION Campaign? - CrowdStrike](#)
9. VirusTotal. "Hi-Zor". [VirusTotal - File - cd07ac5947c643854375603800a4f70e2dfe202c8a1f801204328921cb3a2a4c](#)
10. Microsoft. "Win32/Derusbi". [Win32/Derusbi threat description - Microsoft Security Intelligence](#)
11. GoLinuxCloud. "Reverse Shell". [Reverse Shell Cheat Sheet With Examples \[100% Working\] | GoLinuxCloud](#)
12. MITRE ATT&CK. "Detect Registry and Startup Folder Persistence". [Detect Registry and Startup Folder Persistence \(Windows\), Detection Strategy DET0365 | MITRE ATT&CK®](#)

13. MITRE ATT&CK. “Detect Ingress Tool Transfers via Behavioral Chain”. [Detect Ingress Tool Transfers via Behavioral Chain, Detection Strategy DET0060 | MITRE ATT&CK®](#)
14. Fidelis Threat Research Team. “Introducing Hi-Zor RAT”. <https://www.fidelissecurity.com/threatgeek/archive/introducing-hi-zor-rat/>
15. MITRE ATT&CK. “Execution Prevention”. [Execution Prevention, Mitigation M1038 - Enterprise | MITRE ATT&CK®](#)